

Chapter 5

Database Security

OVERVIEW OF DATABASE SECURITY

- **Privacy** – Ethical and legal rights that individuals have with regard to control over the dissemination and user of their personal information.
- **Database security** – Protection of information contained in the database against unauthorized access, modification or destruction.
- **Database integrity** – Mechanism that is applied to ensure that the data in the database is correct and consistent.

...CON'T

- A good database security management system has:
 - data independence, shared access, minimal redundancy, data consistency, and data integrity
- A good database security management system also has the following characteristics:
 - **Privacy** signifies that an unauthorized user cannot disclose data
 - **Integrity** ensures that an unauthorized user cannot modify data.
 - **Availability** ensures that data be made available to the authorized user unfailingly
 - **Copyright** ensures the native rights of individuals as a creator of information.
 - **Validity** ensures activities to be accountable by law.

...CON'T

- Database system can effectively prevent accidental security and integrity threats from:
 - System error,
 - Improper authorization and
 - Concurrent usage anomalies.
- The levels of security protection, it may start from organization & administrative security, physical & personnel security, communication security and Information systems security.
- ***Database security and integrity*** is about protecting the database from being inconsistent and being disrupted.
 - We can also call it **database misuse**.
- **Database misuse** could be ***Intentional*** or ***Accidental***, where accidental misuse is easier to cope with than intentional misuse.

...CON'T

- *Accidental inconsistency could occur due to:*
 - System crash during transaction processing
 - Anomalies due to concurrent access
 - Anomalies due to redundancy
 - Logical errors
- *Intentional misuse could be:*
 - Unauthorized reading of data
 - Unauthorized modification of data or
 - Unauthorized destruction of data
- Most systems implement good **Database Integrity** to protect the system from accidental misuse.

Levels of Security Measures

- Security measures can be implemented at several levels and for different components of the system.
- These levels are:
 1. **Physical Level:** concerned with securing the site containing the computer system.
 - The backup systems should also be physically protected from access except for authorized users.
 2. **Human Level:** concerned with authorization of database users for access the content at different levels and privileges.
 3. **Operating System:** concerned with the weakness and strength of the operating system security on data files.
 - This also includes protection of data in primary and secondary memory from unauthorized access.
 4. **Database System:** concerned with data access limit enforced by the database system.
 - Access limit like password
 5. **Application Level:** Since almost all database systems allow remote access through terminals or networks, software-level security with the network software is as important as physical security, both on the Internet and networks private to an enterprise.

...CON'T

- We can have different levels of security and authorization on data objects and users, ***who access which data is a policy matter rather than technical.***
- **These policies**
 - should be known by the system: should be encoded in the system.
 - should be remembered: should be saved somewhere (the catalogue)

...CON'T

- **Database Integrity** constraints contribute to maintaining a secure database system by preventing data from becoming invalid and hence giving misleading or incorrect results.
- **Domain Integrity** means that each column in any table will have set of allowed values and can not assume any value other than the one specified in the domain.
- **Entity Integrity** means that in each table the primary key (which may be composite) satisfies both of two conditions:
 1. That the primary key is unique within the table and
 2. That the primary key column(s) contains no null values.
- **Referential Integrity** means that the RDBMS must be set up so as to take appropriate actions to spread a change—in one table—from that table to the other tables where the change must also occur.

Security Issues and general considerations

- **Legal, ethical** and **social** issues regarding the right to access information
 - **Physical control** issues regarding how to keep the database physically secured.
 - **Policy** issues regarding privacy of individual level at enterprise and national level
 - **Operational** consideration on the techniques used (password, etc) to access and manipulate the database
 - **System** level security including operating system and hardware control
-
- The designer and the administrator of a database should first identify the possible threat that might be faced by the system in order to take counter measures.
 - **Threat** may be any situation or event, whether intentional or accidental, that may adversely affect a system and consequently the organization.

...CON'T

- A threat may be caused by a situation or event involving a person, action, or circumstance that is likely to bring harm to an organization
- The harm to an organization may be ***tangible*** or ***intangible***
 - ***Tangible*** – loss of hardware, software, or data
 - ***Intangible*** – loss of credibility or client confidence

...CON'T

- **Examples of threats:**

- Using another persons' means of access
- Unauthorized amendment/modification or copying of data
- Program alteration(making different)
- Inadequate policies and procedures that allow a mix of confidential and normal out put
- Wire-tapping
- Illegal entry by hacker
- Blackmail
- Theft of data, programs, and equipment
- Failure of security mechanisms, giving greater access than normal
- Staff shortages or strikes
- Inadequate staff training
- Viewing and disclosing unauthorized data
- Electronic interference and radiation
- Data corruption owing to power loss or surge
- Fire (electrical fault, lightning strike, arson), flood, bomb
- Physical damage to equipment
- Breaking cables or disconnection of cables
- Introduction of viruses

Countermeasures: Computer Based Controls

- The following are computer-based security controls for a multi-user environment:
- **Authorization**
 - The **granting** of a right or privilege that enables a subject to have legal access to a system or a system's object.
 - Authorization controls can be **built** into the software, and govern not only what system or object a specified user can access, but also what the user may do with it
 - Authorization controls are sometimes referred to as ***access controls***
 - The process of authorization involves authentication of ***subjects*** (i.e. a user or program) requesting access to ***objects*** (i.e. a database table, view, procedure, trigger, or any other object that can be created within the system)

...CON'T

- **Views**

- A view is the dynamic result of one or more relational operations on the base relations to produce another relation.
- A view is a virtual relation that does not actually exist in the database, but is produced upon request by a particular user
- The view mechanism provides a powerful and flexible security mechanism by hiding parts of the database from certain users
- Using a view is more restrictive than simply having certain **privileges** granted to a user on the base relation(s).

...CON'T

- **Backup and recovery**

- Backup is the process of periodically taking a copy of the database and log file (and possibly programs) on to offline storage media.
- Database recovery is the process of restoring the database to a correct state in the event of a failure.
- **Journaling** is the process of keeping and maintaining a log file (or journal) of all changes made to the database to enable recovery to be undertaken effectively in the event of a failure.
- The advantage of journaling is that, in the event of a failure, the database can be recovered to its last known consistent state using a backup copy of the database and the information contained in the log file.
- If no journaling is enabled on a failed system, the only means of recovery is to restore the database using the latest backup version of the database

...CON'T

- **Integrity**

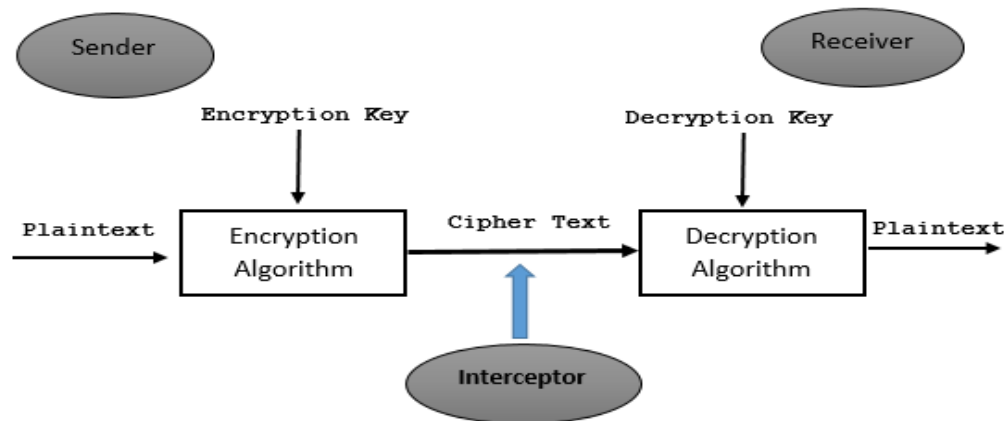
- Integrity constraints contribute to maintaining a secure database system by preventing data from becoming invalid and hence giving **misleading** or **incorrect results**.
- *Domain Integrity*: setting the allowed set of values
- *Entity integrity*: demanding Primary key values not to assume a NULL value.
- *Referential integrity*: enforcing Foreign Key values to have a value that already exist in the corresponding Candidate Key attribute(s) or be NULL.

Encryption

- Encryption is used to **protect** information stored at a particular site or transmitted between sites from being accessed by **unauthorized** users.
- Encryption is the encoding of the data by a special algorithm that renders the data unreadable by any program without the **decryption key**.
- It is not possible for encrypted data to be read unless the reader knows how to **decipher/decrypt** the encrypted data.
- The DBMS can access data after decoding it, although there is a degradation in performance because of the time taken to decode it.
- Encryption also protects data transmitted over communication lines.

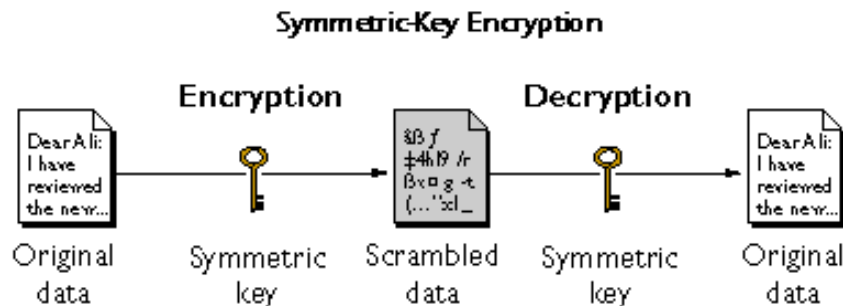
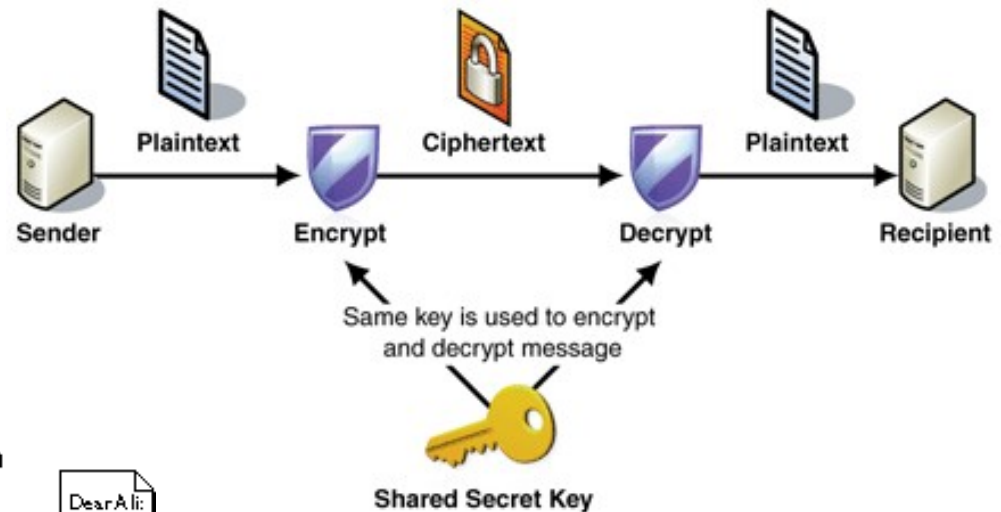
...CON'T

- To transmit data securely over insecure networks requires the use of a **Cryptosystem**, which includes:
 1. An **encryption key** to encrypt the data (plaintext)
 2. An **encryption algorithm** that, with the encryption key, transforms the plaintext into ciphertext
 3. A **decryption key** to decrypt the ciphertext
 4. A **decryption algorithm** that, with the decryption key, transforms the ciphertext



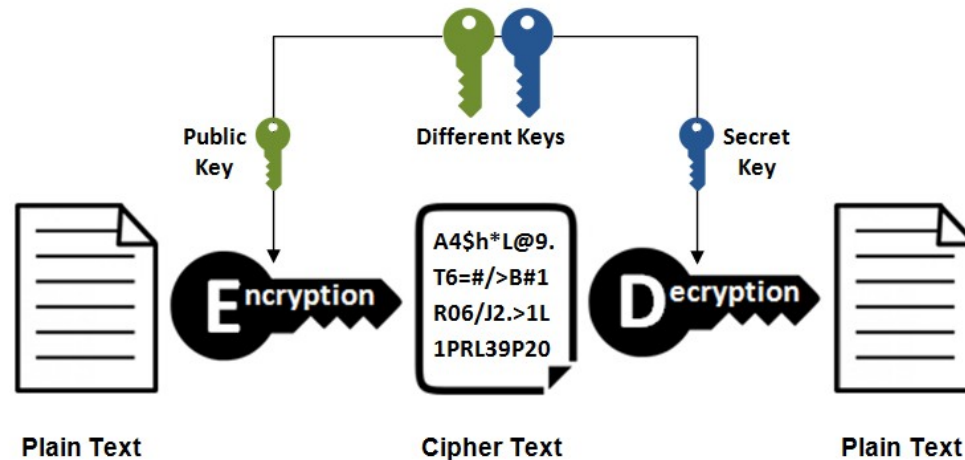
Types of Cryptosystems

- Cryptosystems can be categorized into two:
 1. **Symmetric encryption** – uses the same key for both encryption and decryption and relies on safe communication lines for exchanging the key.



...CON'T

2. **Asymmetric encryption** – uses different keys for encryption and decryption e.g. RSA(Rivest–Shamir–Adleman)



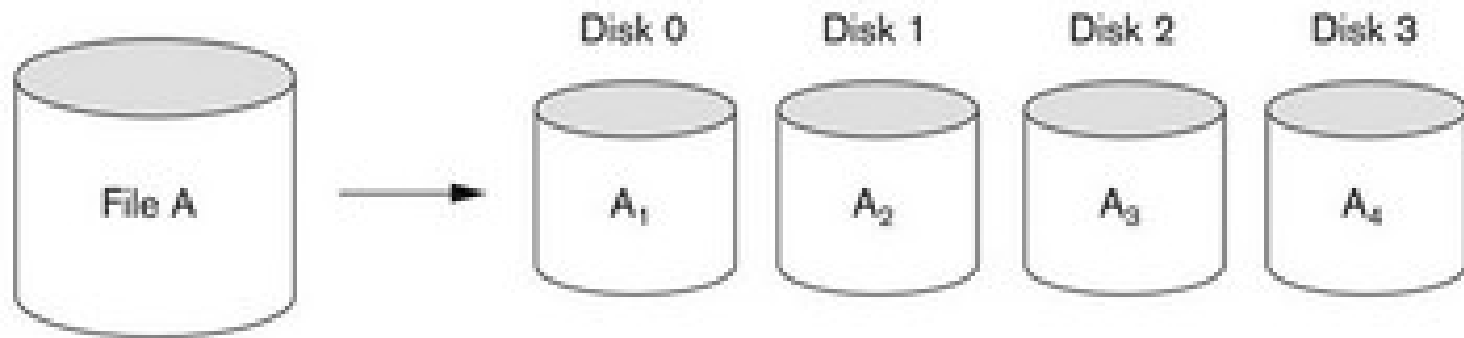
- Generally, symmetric algorithms are **much faster** to execute on a computer than those that are asymmetric.
- In the contrary, asymmetric algorithms are **more secure** than symmetric algorithms.

RAID technology (Redundant Array of Independent Disks)

- The main hardware components that should be fault-tolerant include disk drives, disk controllers, CPU, power supplies, and cooling fans.
- Disk drives are the most vulnerable(attackable) components with the shortest times between failures of any of the hardware components.
- RAID works on having a large disk array comprising an arrangement of several independent disks that are organized to improve reliability and at same time increase performance
- Performance is increased through ***data striping***

...CON'T

- **Data striping** – the data is segmented into equal size partitions (the striping unit) which are transparently distributed across multiple disks.
- Data striping stores data across multiple disks



- **Figure:** Data striping File A striped across four disks

Security at different Levels of Data

- Almost all RDBMSs provide security at different levels and formats of data.
- This includes:-
 1. **Relation Level:** permission to have access to a specific relation.
 2. **View Level:** permission to data included in the view and not in the named relations
 3. **Hybrid (Relation/View):** the case where only part of a single relation is made available to users through View.
- Any database access request will have the following three major components:-
 1. **Requested Operation:** what kind of operation is requested by a specific query?
 2. **Requested Object:** on which resource or data of the database is the operation required to be applied?
 3. **Requesting User:** who is the user requesting the operation on the specified object?

Authentication

- All users of the database will have different access levels and permission for different data objects.
- Is the process of checking whether the user is the one with the privilege for the access level.
- Each user is given a unique identifier, which is used by the operating system to determine who they are.
- Thus the system will check whether the user with a specific **username** and **password** is trying to use the resource.
- Associated with each identifier is a **password**, chosen by the user and known to the operation system, which must be supplied to enable the operating system to authenticate who the user claims to be.

Authorization/Privilege

- Authorization refers to the process that determines the mode in which a particular (**previously authenticated**) client is allowed to access a specific resource controlled by a server.
- Authorization is implemented by using **Views**.
- Views are unnamed relations containing part of one or more base relations creating a customized/personalized view for different users.

...CON'T

- ***Forms of user authorization***

- There are different forms of user authorization on the resource of the database.
- These forms are privileges on what operations are allowed on a specific data object.

- **User authorization on the data/extension**

1. **Read Authorization:** the user with this privilege is allowed only to read the content of the data object.
 2. **Insert Authorization:** the user with this privilege is allowed only to insert new records or items to the data object.
 3. **Update Authorization:** users with this privilege are allowed to modify content of attributes but are not authorized to delete the records.
 4. **Delete Authorization:** users with this privilege are only allowed to delete a record and not anything else.
- Different users, depending on the power of the user, can have one or the combination of the above forms of authorization on different data objects.

...CON'T

- **User authorization on the database schema**
 1. **Index Authorization:** deals with permission to create as well as delete an index table for relation.
 2. **Resource Authorization:** deals with permission to add/create a new relation in the database.
 3. **Alteration Authorization:** deals with permission to add as well as delete attribute.
 4. **Drop Authorization:** deals with permission to delete and existing relation.

Role of DBA in Database Security

- The database administrator is responsible to make the database to be as secure as possible and have the most powerful privilege than every other user.
- The DBA provides capability for database users while accessing the content of the database.
- The major responsibilities of DBA in relation to authorization of users are:
 1. **Account Creation**: involves creating different accounts for different **USERS** as well as **USER GROUPS**.
 2. **Security Level Assignment**: involves in assigning different users at different categories of access levels.
 3. **Privilege Grant**: involves giving different levels of privileges for different users and user groups.
 4. **Privilege Revocation**: involves denying or canceling previously granted privileges for users due to various reasons.
 5. **Account Deletion**: involves in deleting an existing account of users or user groups. Is similar with denying all privileges of users on the database.

Approaches to Database Security

- There are two broader approaches to database security mechanisms:

1) Discretionary security mechanisms

- Grant different privileges to different users and user groups on various data objects
- The privilege is to access different data objects
- The mode of the privilege could be:
 - Read,
 - Insert,
 - Delete,
 - Update files, records or fields.
- Is more flexible

...CON'T

- 2) **Mandatory security mechanisms**
 - Enforce multilevel security
 - classifying data and users into various security classes (or levels) and implementing the appropriate security policy of the organization.
 - Each **data object** will have certain **classification level**
 - Each **user** is given certain **clearance level**
 - Only users who can pass the clearance level can access the data object
 - Is comparatively not-flexible/rigid
- The ability to classify user into a hierarchy of groups provide a powerful tool for administering large systems with thousands of users and objects.
- A database system can support one or both of the security mechanisms to protect the data.

Statistical Database Security

- Statistical databases contain information about individuals which may not be permitted to be seen by others as individual records.
- Such databases may contain information about various populations.
- **Example:** Medical Records, Personal Data like address, salary, etc
- Such kind of databases should have special security mechanisms so that confidential information about people will not be disclosed for many users.
- Thus statistical databases should have additional security techniques which will protect the retrieval of individual records.
- Only queries with statistical aggregate functions like **Average, Sum, Min, Max, Standard Deviation, Mid, Count**, etc should be executed.

END